

Computer and Network Security

Tutorial Worksheet A

Description. This tutorial worksheet covers the following topics:

- Networking (Overview).
- Password-based authentication.
- Security services.
- Security policy.
- Identifying phishing emails.
- Security Aspects.
- Attack classification.
- Vulnerability identification.

Exercise 1 (Networking)

Consider the following network communication protocols: TCP, UDP, TLS, SSL, HTTP, HTTPS, DNS, DHCP, ARP, ICMP, IGMP, Telnet, SSH, SMTP, IMAP, OSPF, POP3, Ethernet, SMB, SNMP, RPC, BGP, RARP, NFS, RIP, IPv4, IPv6, BOOTP, FTP, TFTP, and UPnP.

1. Considering the TCP/IP suite, complete the following table:

Protocol	Layer	Description
...	...	...
...	...	...
...	...	...

2. Select all application-level protocols from the above list and assign to them their corresponding communication port. Note that certain protocols use multiple ports.
3. List the set of protocols that are used within your local network when you open a terminal on your PC and execute the command `$ping www.ensia.edu.dz`, for the very first time.
4. Consider the scenario where two computers (PC1 and PC2) are connected to the Internet via a local network. Each computer has a private IPv4 address (e.g., 192.168.1.44 and 192.168.1.55), and both computers get natted to a unique public IPv4 address (provided by the ISP) for any outgoing traffic. Describe how NAT operates when the two computers simultaneously send ping requests to a same destination, e.g., `www.ensia.edu.dz`.
5. Explain how routers, which typically operate on Layer 3, perform natting (NAT), a process that requires access to communication port fields in TCP and UDP segments (Layer 4).

6. List the set of protocols that are used within your local network when you open a web-browser on your PC and type `https://www.ensia.edu.dz`, for the very first time.
7. Which application protocols send their data in plaintext?
8. Use an MSC (Message Sequence Chart) to illustrate the process of the TCP three-way-handshake. Your diagram should show the used TCP segments, their sequence numbers, their acknowledgement numbers, and their TCP flags (SYN and ACK, in particular).
9. Discuss how the TCP three-way-handshake can be exploited to cause harm to the destination computer. How do you call the attack?
10. Describe what happens when a user sends a ping request with an ICMP's data field carrying around 65,900 bytes of data. Is this generally allowed? Can this be used as an exploit?

Exercise 2 (Password-based Authentication)

Computer users routinely provide a username and password, a.k.a., credentials, to gain entry to either a local computer or a remote account. The computer stores sufficient information to test whether the password matches the one for that username (i.e., user).

1. Discuss five different approaches to defeat password-based authentication.
2. Consider a system that implements a password-based authentication system. The system stores all the usernames and their corresponding passwords' SHA512-hashes in a dedicated file `p_hash` (e.g., in GNU/Linux systems — password hashes are stored in `/etc/shadow`). Write an algorithm that exploits the file `p_hash` to crack the password of arbitrary registered users (i.e., trawling). Are there known software tools that implement your algorithm?
3. Propose solutions (countermeasures) to make the above system more secure and immune to classical password-cracking attacks than it currently is.
4. Many systems nowadays define and impose a password composition policy on the used passwords. The policy defines rules specifying minimum lengths (e.g., 8 or 10), and requiring password characters from, e.g., three (or perhaps all) LUDS categories: lowercase (L), uppercase (U), digits (D), special characters (S). It is claimed that following the policy (i.e., increase in complexity) results in creating “strong passwords”. Discuss attack scenarios where you explain that term “strong” is not always strong (misleading term).
5. Would you update your answer above if we dealt with passphrases instead of passwords?
6. Consider a system that implements a password recovery mechanism where the user is asked to answer some security questions, input a confirmation code (received on the mobile-phone), and respond to a CAPTCHA challenge. Propose a malicious scenario, where an attacker misleads a legitimate user to unawaresly answer all those password reset questions and manage to reset the password, locking the legitimate user out. Use an MSC (Message Sequence Chart) to illustrate your attack scenario. (Hint: interleaving attack).

7. Many systems nowadays use password managers to store and retrieve passwords (used for various services) as a mean to cope with overwhelming numbers of passwords (e.g., ensia, gmail, linkedIn, facebook, amazon, etc). Instead of remembering many passwords (if different), the user only remembers one “master password”. The password manager may be integrated as an operating system utility (E.g., macOS Keychain uses the OS login password as the master password), or be a stand-alone client application (e.g., Microsoft Authenticator), a browser built-in feature (or a plugin, e.g., PwdHash), or a cloud-based service (e.g., LastPass, 1password, ...). Password managers employ two main approaches: password wallet (vault) and derived passwords.
 - Explain how some password managers provide a certain resistance against phishing.
 - Analyze password managers’ security to show that it delivers fewer security advantages (usability, efficiency, ...) than expected (they are password “concentrators”).
 - Among web-based password managers, there is PwdHash from Stanford university. Which approach does it use? and why it is not as widely used today.
8. One of the interesting authentication methods, is the graphical-password schemes. In such schemes, a user goes through a registration phase where they have to memorize a drawn pattern (pure recall), a set of click-point on an image (cued recall), or a set of images — e.g., faces — (recognition). Provide 05 disadvantages related to this auth-scheme.
9. Another mechanism to prove the human-nature of a user Vs robot (or bots) is the use of CAPTCHAs. CAPTCHAs use various ATT (Automated Turing Test) techniques such as character recognition (CR), audio recognition (AUD), image recognition (IR), or cognitive challenges involving puzzles (COG). They have proven to be effective against bots-based attacks (e.g., bulk-posting on forums) on web-services. Discuss 03 possible attack scenarios where an attacker may bypass CAPTCHA authentication using a malicious program.

Exercise 3 (Security Services)

Security services are fundamental properties to enforce the protection of information systems. Various mechanisms and protocols are adopted to guarantee a certain level of those services.

1. What are the five fundamental security services? Explain them.
2. Provide two examples of mechanisms that are used in real-life to provide and guarantee a certain level of each fundamental service.
3. Propose a ranking for those security services (i.e., from the most important to the least important) and provide arguments (examples) to support your proposition.
4. List five other “non-fundamental” security services and explain their function.
5. Which security services may get compromised when a computer is infected by a malware?
6. Which security service does digital-watermarking try to enforce?

Exercise 4 (Security Policy)

The purpose of a security policy is to establish a framework that helps safeguard an organization’s sensitive data, systems, and resources from unauthorized access, disclosure, alteration, and destruction. It also specifies the procedures that should be applied when security incidents happen (e.g., during or following a cyberattack).

Consider the case where you have managed to build your own company and decided to set up a security policy to protect its assets and reputation. Use the following table as a template to describe the key components to be considered as well as their related risks and threats in the case where they are not considered.

Aspects (Key Components)	Description	Related risks and threats
Scope and Purpose	...	...
Roles and Responsibilities	...	...
Access Controls	...	...
Data Classification	...	...
Acceptable Use	...	...
Password Management	...	...
Incident Response	...	...
Network Security	...	...
Physical Security	...	...
Security Awareness and Training	...	...
Compliance with Regulations	...	...

Exercise 5 (Phishing)

Phishing is a social-engineering attack methodology where an attacker use deceptive techniques (e.g., psychological manipulation) to trick individuals into taking actions (e.g., clicking on a link, submitting a form, ...) that would result in divulging sensitive information such as login credentials, personal details, or financial information. The attacker may impersonate trusted entities, such as banks, government agencies, or popular websites, to gain the trust of the victim.

1. Your school runs an authentication server where students can manage the credentials of their accounts through a web-application (at <https://authentication.ensia.edu.dz>). Based on the schools’ security policy, the ITS department (which is the Information Technology Security department at ENSIA) may send you an email to kindly remind you to update your credentials every 03 months. You can reach ITS over the phone by dialing +213 23112233. Also, you can walk into their offices, at work time, to ask questions.

During a business day, you receive the following emails from its.ise.dept@ensia.edu.dz (i.e., from ITS). Analyze the below 07 case scenarios and determine phishing patterns that would classify each scenario as phishing attempts instead of legitimate communications. Define your standard way to detect phishing emails:

● Case 01:

[Urgent] Update your account credentials

student-whoeveryouare@ensia.edu.dz

[Urgent] Update your account credentials

Good day:

We hope this email finds you in good health.

To preserve your student account, you'll have to update your credential before midnight. please login at <https://authentication.ensia.edu.dz> and update your credentials.

Looking forward for your cooperation,

Regards,

--



Information Technology Security

ISE Department
ENSIA

✉ authentication@ensia.edu.dz
☎ +213 23112233
📍 Pôle technologique de Sidi Abdellah
🌐 ensia.edu.dz



The content of this email is confidential and intended for the recipient specified in message only. It is strictly forbidden to share any part of this message with any third party, without a written consent of the sender. If you received this message by mistake, please reply to this message and follow with its deletion, so that we can ensure such a mistake does not occur in the future.

● Case 02:

[Urgent] Update your account credentials

student-whoeveryouare@enisa.edu.dz

[Urgent] Update your account credentials

Good day:

We hope this email finds you in good health.

To preserve your student account, you'll have to update your credential before midnight. please login at <https://authentication.ensia.edu.dz@rb.gy/6bfqgh> and update your credentials.

Looking forward for your cooperation,

|

Regards,



Information Technology Security

ISE Department
ENSIA

✉ authentication@ensia.edu.dz
☎ +213 23112233
📍 Pôle technologique de Sidi Abdellah
🌐 ensia.edu.dz



The content of this email is confidential and intended for the recipient specified in message only. It is strictly forbidden to share any part of this message with any third party, without a written consent of the sender. If you received this message by mistake, please reply to this message and follow with its deletion, so that we can ensure such a mistake does not occur in the future.

● Case 03:

[Urgent] Update your account credentials

student-whoeveryouare@enisa.edu.dz

[Urgent] Update your account credentials

Good day:

We hope this email finds you in good health.

To preserve your student account, you'll have to update your credential before midnight. please login at <https://authentication.ensia.edu.dz> and update your credentials.

Looking forward for your cooperation,

Regards,



Information Technology Security
ISE Department
ENSIA

✉ authentication@ensia.edu.dz
☎ +213 23112233
📍 Pôle technologique de Sidi Abdellah
🌐 ensia.edu.dz



The content of this email is confidential and intended for the recipient specified in message only. It is strictly forbidden to share any part of this message with any third party, without a written consent of the sender. If you received this message by mistake, please reply to this message and follow with its deletion, so that we can ensure such a mistake does not occur in the future.

● Case 04:

[Urgent] Update your account credentials

student-whoeveryouare@enisa.edu.dz

[Urgent] Update your account credentials

Dear Students:

We hope this email finds you in good health.

To preserve your student account, we ask you to update your credentials by January 5th, 11:59 pm. Please login at <https://authentication.ensia.edu.dz> to update your credentials.

Looking forward for your cooperation,

Regards,



Information Technology Security
ISE Department
ENSIA

✉ authentication@ensia.edu.dz
☎ +213 23112233
📍 Pôle technologique de Sidi Abdellah
🌐 ensia.edu.dz



The content of this email is confidential and intended for the recipient specified in message only. It is strictly forbidden to share any part of this message with any third party, without a written consent of the sender. If you received this message by mistake, please reply to this message and follow with its deletion, so that we can ensure such a mistake does not occur in the future.

- Case 05:

[Urgent] Update your account credentials

student-whoeveryouare@ensia.edu.dz

[Urgent] Update your account credentials

Dear Students:

We hope this email finds you in good health.

To preserve your student account, we ask you to update your credentials by January 5th, 11:59 pm. Please login at <https://t.ly/LFJOQ> to update your credentials.]

Looking forward for your cooperation,

Regards,



Information Technology Security

ISE Department
ENSIA

✉ authentication@ensia.edu.dz
☎ +213 23112233
📍 Pôle technologique de Sidi Abdellah
🌐 ensia.edu.dz



The content of this email is confidential and intended for the recipient specified in message only. It is strictly forbidden to share any part of this message with any third party, without a written consent of the sender. If you received this message by mistake, please reply to this message and follow with its deletion, so that we can ensure such a mistake does not occur in the future.

- Case 06:

[Urgent] Update your account credentials

student-whoeveryouare@ensia.edu.dz

[Urgent] Update your account credentials

Dear Students:

We hope this email finds you in good health.

To preserve your student account, we ask you to update your credentials by January 5th, 11:59 pm. Please login at [🌐](https://t.ly/LFJOQ) to update your credentials.

Looking forward for your cooperation,

Regards,



Information Technology Security

ISE Department
ENSIA

✉ authentication@ensia.edu.dz
☎ +213 23112233
📍 Pôle technologique de Sidi Abdellah
🌐 ensia.edu.dz



The content of this email is confidential and intended for the recipient specified in message only. It is strictly forbidden to share any part of this message with any third party, without a written consent of the sender. If you received this message by mistake, please reply to this message and follow with its deletion, so that we can ensure such a mistake does not occur in the future.

- Case 07:

[Urgent] Update your account credentials

student-whoeveryouare@ensia.edu.dz

[Urgent] Update your account credentials

Dear Student:

We hope this email finds you well. We would like to bring to your attention an important matter regarding your student account credentials.

Our system indicates that your account credentials, specifically your password, are due for an update as part of our routine security measures. To ensure the continued security and integrity of your account, we kindly request that you update your password at your earliest convenience.

To update your account information, you can login at: <https://www.authentication.edu.dz>

Please note that failure to update your password within the next 3 days will result in the automatic locking of your account for security reasons. In the event of an account lockout, you will need to contact our support team for assistance in restoring access.

If you encounter any issues or have questions regarding this update, feel free to reach out to our support team at its.ise.dept@ensia.edu.dz. Thank you for your prompt attention to this matter. We appreciate your cooperation in maintaining the security of our system.

Regards,

[Report Phishing](#)



Information Technology Security
ISE Department
ENSIA

✉ authentication@ensia.edu.dz
☎ +213 23112233
📍 Pôle technologique de Sidi Abdellah
🌐 ensia.edu.dz



2. You are a Windows user (e.g., Microsoft Windows 11) and receive an email, from Microsoft, that contains an attached file, claiming important security update. Explain what should you do: Install the update, verify that the source of the email is Microsoft (@microsoft.com), or delete the email and go back to your preoccupation.

Exercise 6 (Security Aspects)

Place the following keywords in the right security aspect location in the table below: (1) Trapdoors, (2) CCTV cameras, (3) lighting projectors, (4) smart locks, (5) fire extinguishers, (6) smoke detectors, (7) anti-malware, (8) back-up power system, (9) firewall, (10) HVAC system, (11) shredding machines, (12) free software, (13) backdoors, (14) cybersecurity training, (15) Thorny bushes, (16) HTTPS, (17) disallow rogue devices, (18) tossed USBs in parking lots, (19) running services, and (20) regular system update.

Security Aspects				
Physical	Social	Network	Application	Operating System
...	...	...	...	...
...	...	...	...	...
...	...	...	...	...

Exercise 7 (Attack Classification)

For the following attacks, determine which security service do they compromise (i.e., authentication, confidentiality, etc). Also, for each attack, give a brief explanation, determine the exploited vulnerability, and provide possible countermeasures to fix the vulnerability:

1. Ping of Death.
2. Buffer overflow on the stack.
3. Replaying an old packet.
4. Sending a spoofed email.
5. Spray-paint CCTV security cameras.
6. Cracking password.
7. ICMP Smurf attack.
8. TCP flooding.
9. Packet sniffing.
10. Smash server's room door.
11. Cloning RFID access cards.
12. Generating spoofed IP datagrams.
13. Integer overflow attack.
14. Cut accessible Ethernet cables.
15. Zip bombing attack.
16. RFID relay attack.
17. Wi-Fi wardriving.
18. HTTP cookie hijacking.
19. SQL injection attack.
20. Shoulder surfing PIN codes at an ATM.
21. Drawing nasty graffiti on company's wall.
22. Corrupt Linux kernel files.

Exercise 8 (Vulnerability Identification)

Analyze the following source codes to find vulnerabilities:

1. The following code snippet is used in a gaming machine where the user, after paying 50 Dinars, is asked to input a value that is less than 10 to win some money. Find a vulnerability in this code that if exploited would allow a user to win more than 1050 Dinars. What is this vulnerability, and how can you fix it?

```
1  #include <stdio.h>
2  #include <stdlib.h>
3  #include <time.h>
4
5  void main()
6  {
7      int user_Input_Value;
8      int system_Winning_Factor = rand() % 100 + 1;
9
10     printf("Input a vauue that is less than 10 to win \n");
11     scanf("%d", &user_Input_Value);
12
13     if(user_Input_Value*100 <= 1000)
14     {
15         printf("Congrats! you won %d Dinars \n", (user_Input_Value*system_Winning_Factor)+50);
16     }
17     else
18     {
19         printf("Too bad! you lost 50 Dinars\n");
20     }
21     return;
22 }
```

2. The following C code is used to implement an authentication mechanism to allow authorized and trusted users to access some resources. The administrator has set up a password “ensia24” and shared the password with authorized users. Find the vulnerability that allows an unauthorized user to bypass the authentication mechanism without knowing the password and get successfully logged in. The malicious user does not know the password, but know how the program was designed (i.e., the structure). Fix the vulnerability.

```
1  #include <stdio.h>
2  #include <string.h>
3  #include <unistd.h>
4
5  void main()
6  {
7      char password[8]={'e','n','s','i','a','2','5','\0'};
8      char pass[8];
9      char username[8];
10     unsigned int miss=0;
11
12     printf("Input your username: ");
13     gets(username);
14     X: printf("Input your password: ");
15     gets(pass);
16     if(strncmp(password, pass, 8) == 0)
17     {
18         printf("Successful login as %s \n", username);
19         execlp("/bin/sh", "/bin/./sh", (char *) NULL);
20     }
21     else
22     {
23         printf("Login failed! \n");
24         miss++;
25         if(miss==3);
26         else goto X;
27     }
28     printf("Exit ... see you next time %d \n", miss);
29     return;
30 }
```

3. The above code got updated to provide a better security. Find another vulnerability that would allow a malicious user to crack this authentication mechanism and possibly get a successful login. The malicious may exploit the vulnerability and use tools like John.

```
1 #include <stdio.h>
2 #include <string.h>
3 #include <unistd.h>
4
5 void main()
6 {
7     char username[8];
8     unsigned int miss=0;
9     char pass[8];
10    char password[8]='e','n','s','i','a','2','5','\0';
11
12    printf("Input your username: ");
13    gets(username);
14    X: printf("Input your password: ");
15    gets(pass);
16    if(strncmp(password, pass, 8) == 0)
17    {
18        printf("Successful login as %s \n", username);
19        execlp("/bin/sh", "/bin/./sh", (char *) NULL);
20    }
21    else
22    {
23        printf("Login failed! \n");
24        miss++;
25        if(miss==3);
26        else goto X;
27    }
28    printf("Exit ... see you next time %d \n", miss);
29    return;
30 }
```

Exercise 9 (More Phishing)

Massoud owns an account at `ensia.edu.dz`. This account is protected using a complex password plus two-factor authentication. Massoud has always felt secure. One day, Massoud discovered that his email account was hacked—he realized that somebody broke into his mailbox, read emails, and sent emails to harshly insult other people and colleagues. Furthermore, he discovered that the same hacker broke into his Whatsapp account and sent insulting pictures to his contacts. Before this incident, Massoud remembers that the last time he used his laptop, he logged into his email account and to his Whatsapp account. Habitually, he takes random screenshots of his display monitor. Below are two screenshots, seconds before he logged into his two accounts. Analyze the two screenshots to discover evidences justifying the incident and explain what really happened to Massoud, and how he got hacked that hard.



